RELATÓRIO DE RECONHECIMENTO
e MAPEAMENTO - SACI

Alvo: OWASP Juice Shop	**Fase:** Reconhecimento Passivo e Ativo
Nome: Julio Cesar Crispim Silva	**Trilha:** Red Team

1. CONTEXTUALIZAÇÃO

O relatório detalha os resultados da fase de reconhecimento e descoberta realizada no site OWASP Juice Shop. O objetivo principal foi mapear rotas e endpoints, identificar vazamentos de dados sensíveis em arquivos e rastrear informações de identificação do usuário administrador.
A aplicação foi feita via container Docker. O tráfego HTTP/HTTPS gerado durante a navegação foi interceptado e modificado através do Burp Suite, permitindo a análise detalhada de requisições, respostas, cabeçalhos, arquivos JavaScript e endpoints de API REST.

2. METODOLOGIA DE RECONHECIMENTO COM BURP SUITE

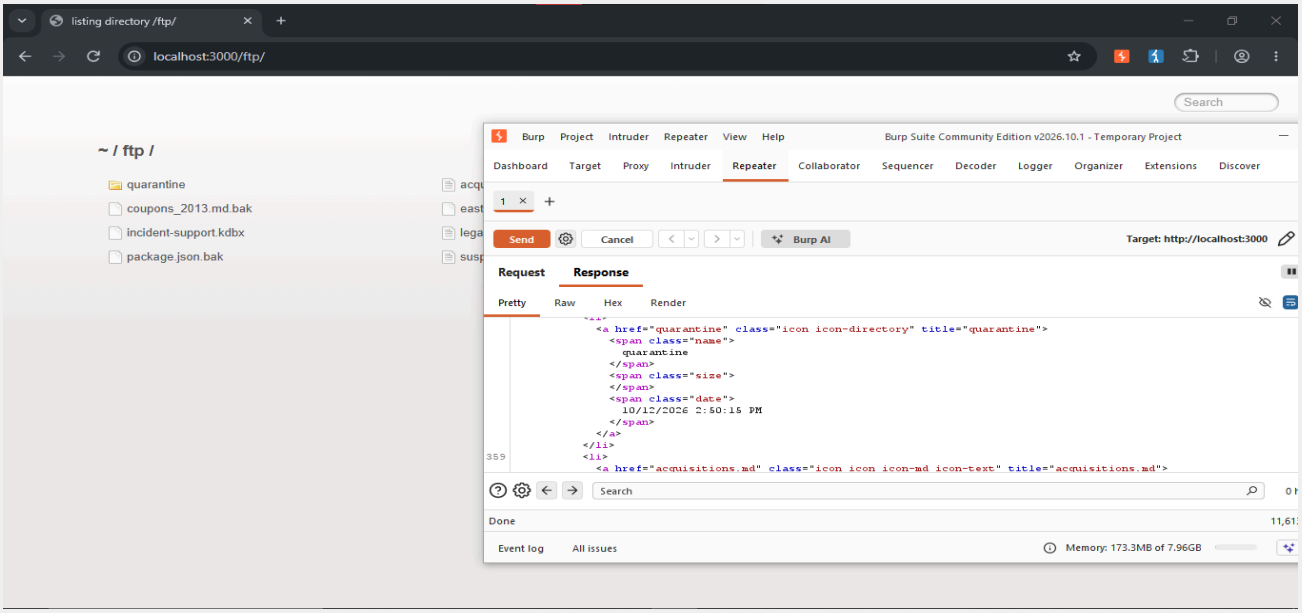
1. *Interceptação e HTTP History:* Captura e análise das requisições REST geradas pelo navegador, revelando endpoints ocultos e dados expostos sem autenticação.
2. *Análise de Sitemap:* Mapeamento no Burp Target Map para identificar estruturas de diretórios, assets e arquivos expostos.
3. *Manipulação de Requisições (Repeater):* Reenvio e alteração de payloads JSON para testar validações do servidor, contorno de controles de lógica (CAPTCHA, Avaliações) e IDOR.
4. *Auditoria de Endpoints REST:* Análise de dados JSON retornados por APIs de fundo (/api/ e /rest/) .
5. *Interceptação e Injeção de Parâmetros:* Alteração em tempo real de requisições GET/POST via Intercept para validação de sanitização de entradas (XSS, inputs inválidos e controle de acesso)

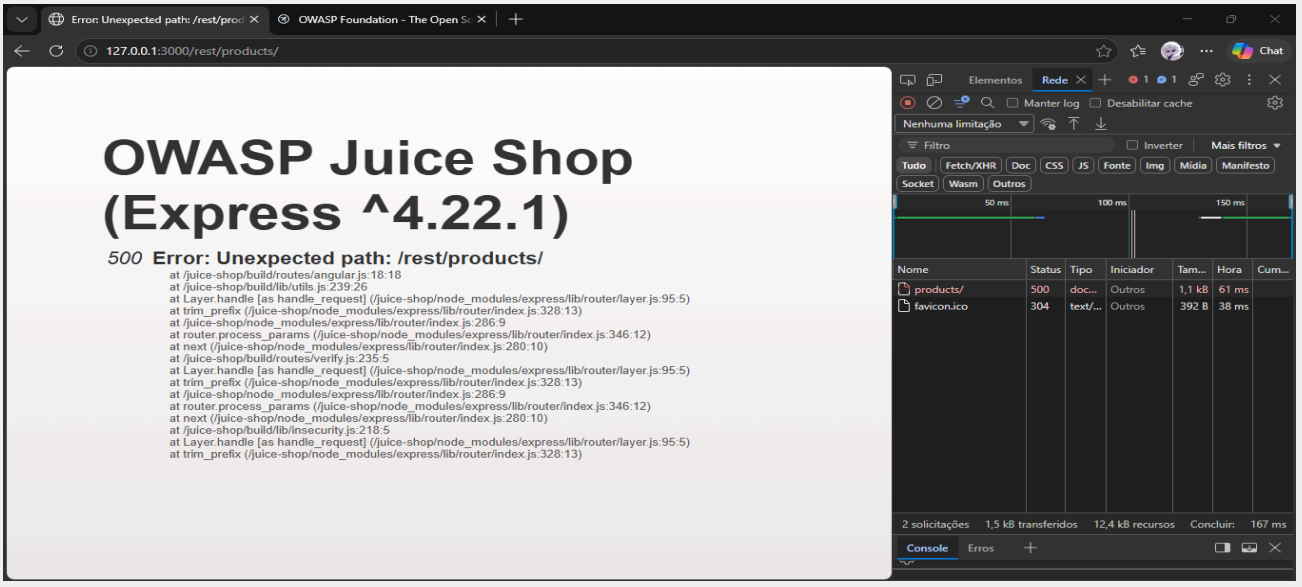
3. ANÁLISE DETALHADA DE ALGUNS ACHADOS:

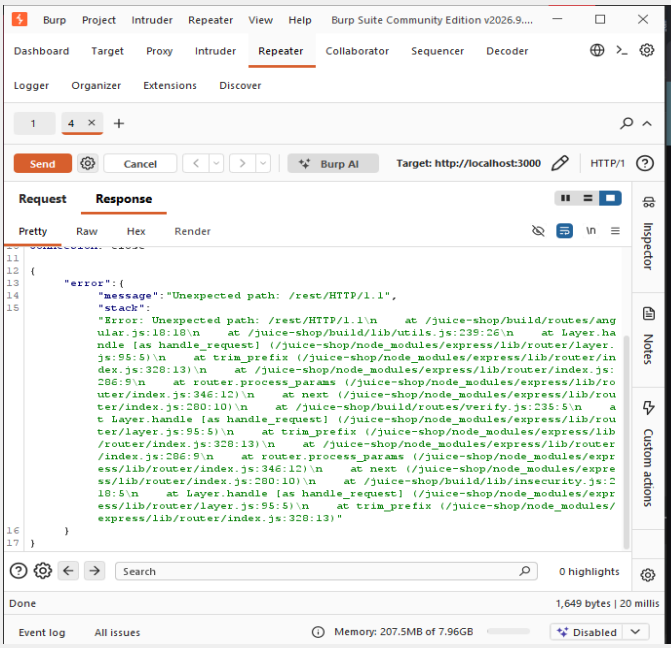
3.1 EXPOSIÇÃO DE ARQUIVOS CONFIDENCIAIS E SERVIDOR (FTP / ERROS HTTP)

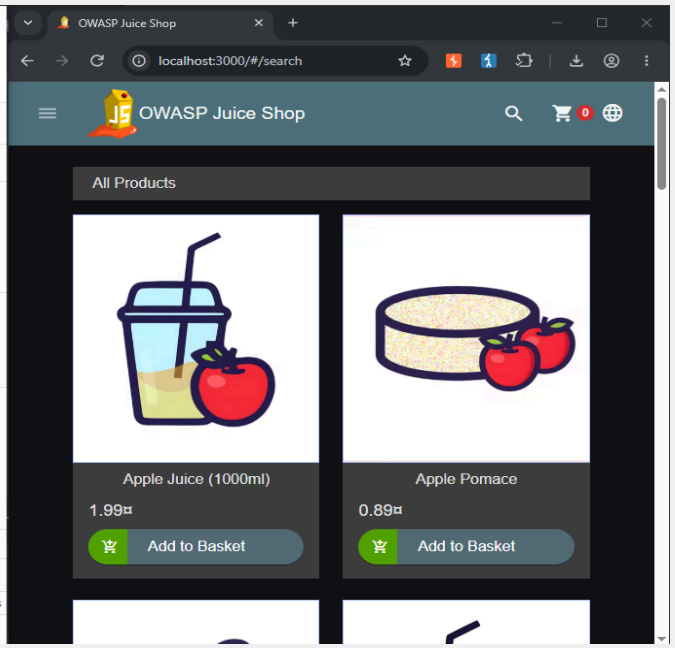
A análise da aplicação pela navegação até o endpoint http://localhost:3000/ftp revelou graves falhas na gestão de arquivos e tratamento de exceções do servidor, permitindo acesso a listagem de diretórios sem autenticação:

- ➔ *Exposição Sensível via Protocolo FTP (legal.md):* Ao manipular a requisição do arquivo legal.md na rota FTP da aba “About Us”, foi possível extrair a listagem completa de arquivos confidenciais diretamente pelo Burp Suite, incluindo: quarantine , acquisitions.md , announcement_encrypted.md , encrypt.pyc , coupons_2013.md.bak , eastere.gg , incident-support.kdbx, package.json.bak e suspicious_errors.yml.
- ➔ *Divulgação Inadequada de Caminhos:* A tentativa de acessar diretórios restritos via HTTP gera mensagens de erro sem sanitização, expondo a estrutura interna de pastas do sistema operacional do servidor.


listing directory /ftp/
localhost:3000/ftp/
~ / ftp /
quarantine
coupons_2013.md.bak
incident-support.kdbx
package.json.bak
Burp Suite Community Edition v2026.10.1 - Temporary Project
Request
Response
Target: http://localhost:3000


127.0.0.1:3000/rest/products/
OWASP Juice Shop (Express ^4.22.1)
500 Error: Unexpected path: /rest/products/

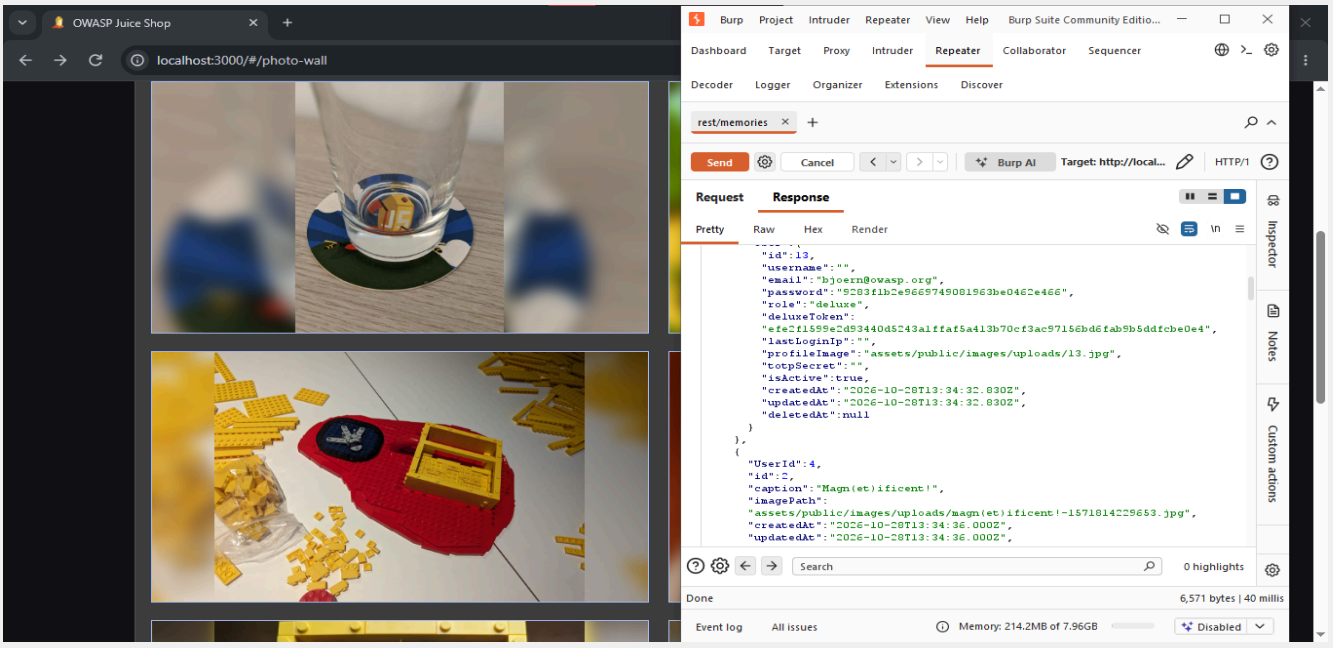

Burp Suite Community Edition v2026.9....
Request
Response
"error":{
"message":"Unexpected path: /rest/HTTP/1.1",

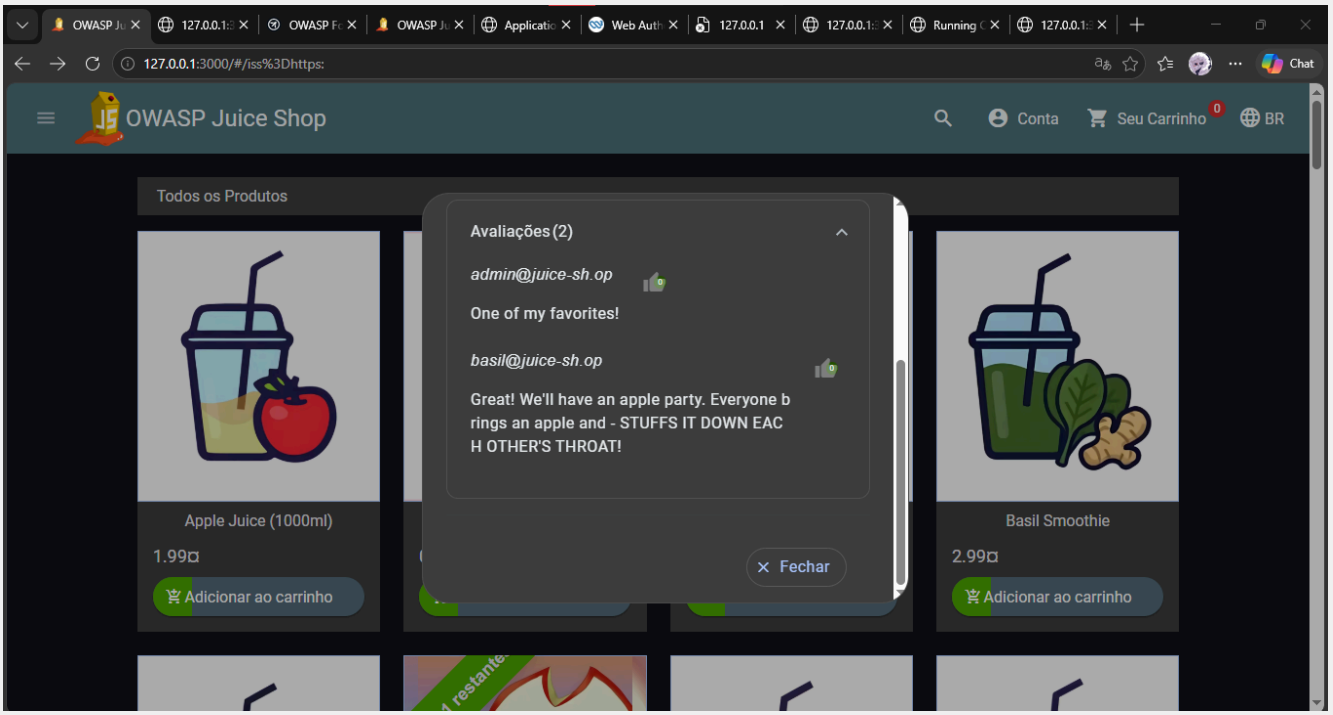

OWASP Juice Shop
localhost:3000/#/search
All Products
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket

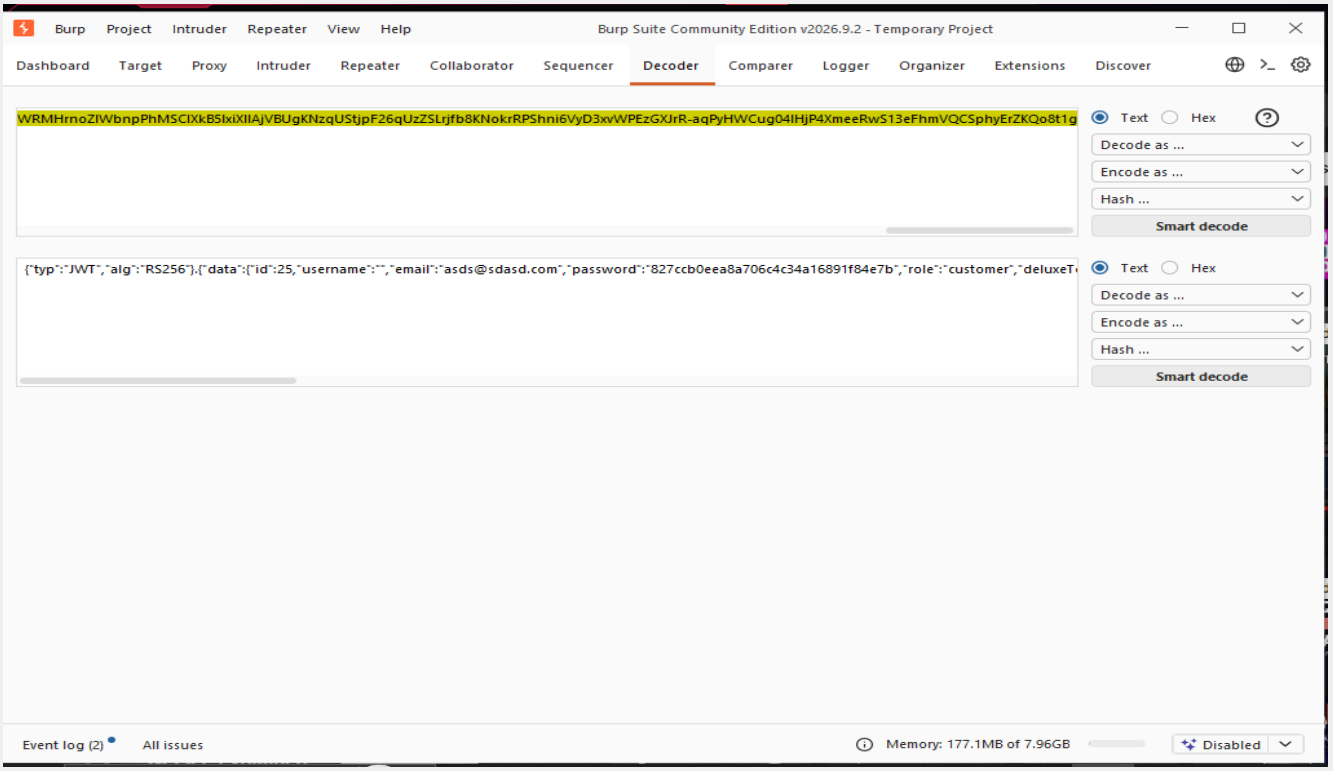
3.2. VAZAMENTO DE DADOS SENSÍVEIS E AUTENTICAÇÃO

O consumo de endpoints REST sem a devida filtragem expõe dados privados dos usuários do sistema e da infraestrutura de autenticação:

- ➔ *Exposição Indevida no /rest/Memories :* O endpoint do Mural de Fotos retorna requisições contendo objetos completos de usuários, vazando ID, e-mail e o hash da senha armazenado no banco de dados.
- ➔ *E-mails Expostos na Interface Pública:* As avaliações e comentários exibidos na página inicial da aplicação exibem abertamente os e-mails dos autores.
- ➔ *Decodificação do Token JWT:* O token JWT emitido após a autenticação carrega dados sensíveis do perfil codificado em Base64, podendo ser descriptografado facilmente.

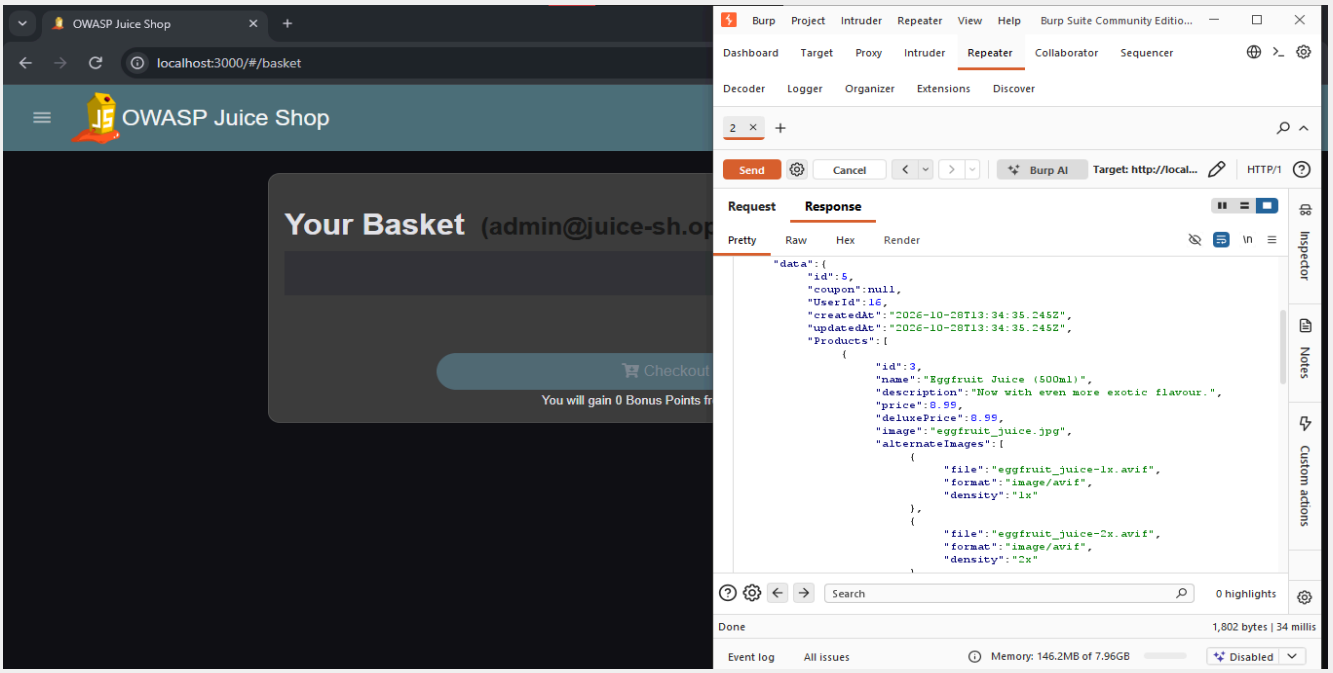






3.3. CONTROLE DE ACESSO QUEBRADO (IDOR NO CARRINHO)

A aplicação apresenta uma grave falha de Insecure Direct Object Reference (IDOR) na gestão do carrinho de compras dos clientes:
Ao adicionar um item ao carrinho, o endpoint REST retorna os dados do carrinho correspondente ao ID do usuário (exemplo: /rest/basket/6). Ao interceptar a requisição no Burp Suite e alterar o parâmetro numérico da URL para outros valores (ex: /rest/basket/1 , /rest/basket/2), é retornado o conteúdo completo dos carrinhos de outros usuários, expondo produtos selecionados, valores e identificadores vinculados sem requerer autorização.



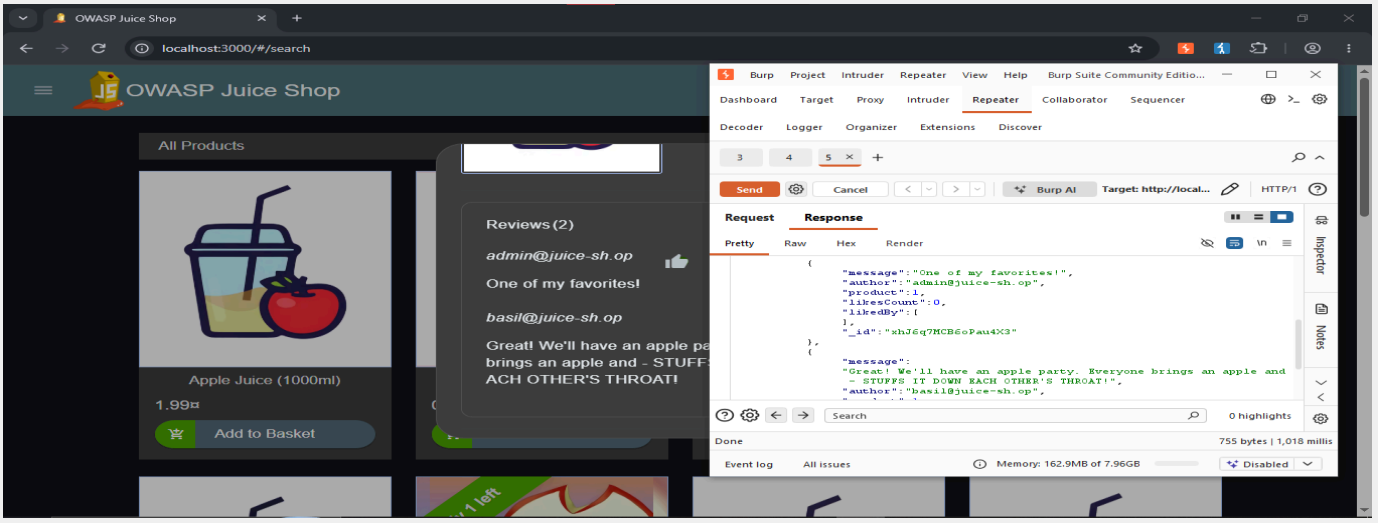
4. RASTREAMENTO E IDENTIFICAÇÃO DA CONTA ADMINISTRADORA

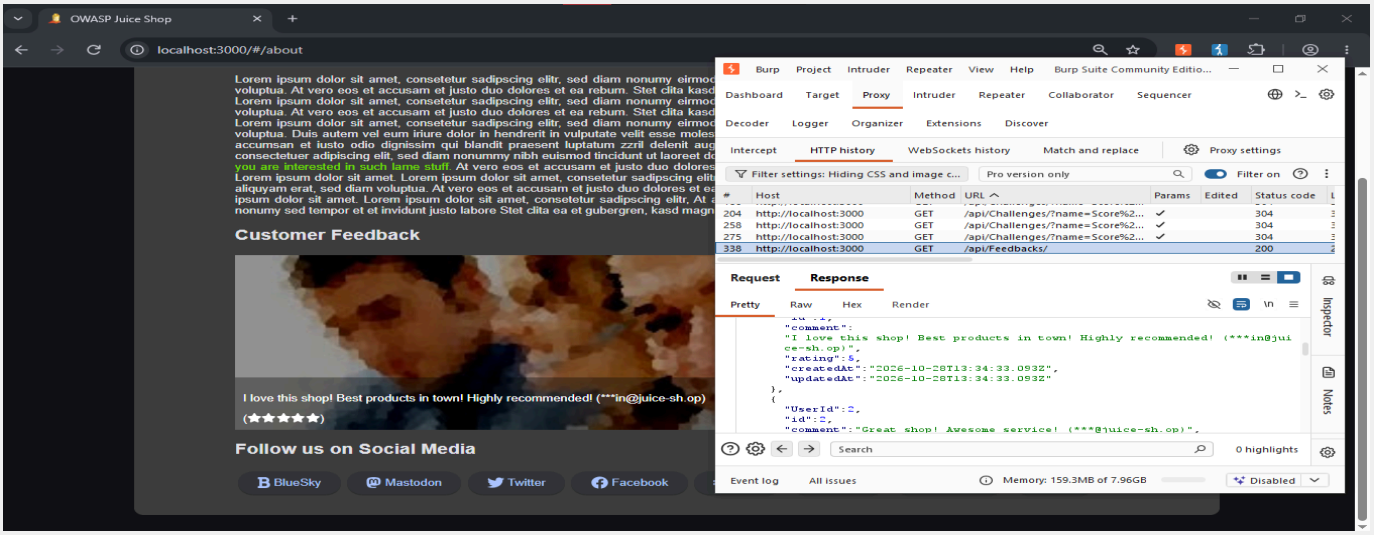
Durante a análise no Burp Suite, utilizou-se uma combinação de dois métodos para rastrear e confirmar o e-mail do administrador:

- ➔ *Método A - Interceptação da API de Avaliações de Produtos:* Além do comentário na página inicial do site pelo email administrador, ao navegar e clicar nos detalhes dos produtos (como a Apple Juice), o frontend dispara uma requisição GET /rest/products/3/reviews. Examinando a resposta JSON no Burp Suite HTTP History, constatou-se que o primeiro comentário registrado no sistema pertencia ao usuário autor com o e-mail cadastrado explicitamente.
- ➔ *Método B - Feedbacks em "About Us":* Na seção About Us (/#/about), a aplicação carrega um carrossel de depoimentos de clientes e fundadores. A inspeção do tráfego capturado revelou referências diretas ao e-mail da conta principal do sistema, podendo identificar que o administrador possui o ID 1 (permitindo assim SQLi).

Resultado da Identificação da Conta Privilegiada

E-mail do Administrador: admin@juice-sh.op (além do “bjoern.kimminich@gmail.com” encontrado em rest/memories com sua senha hash expostas) **ID do Usuário no Banco:** 1

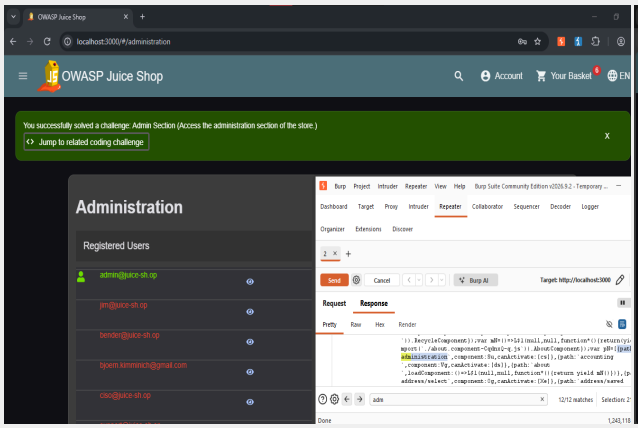


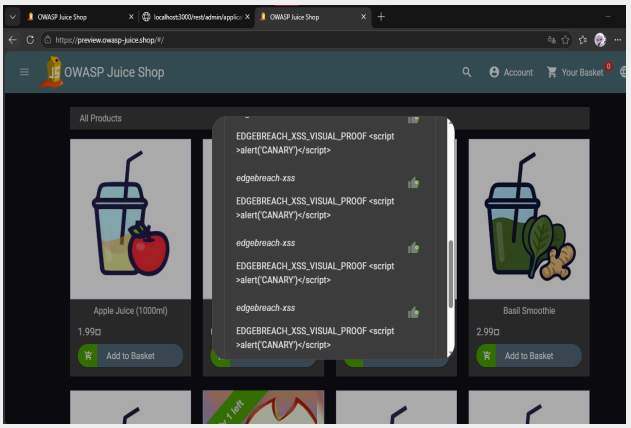


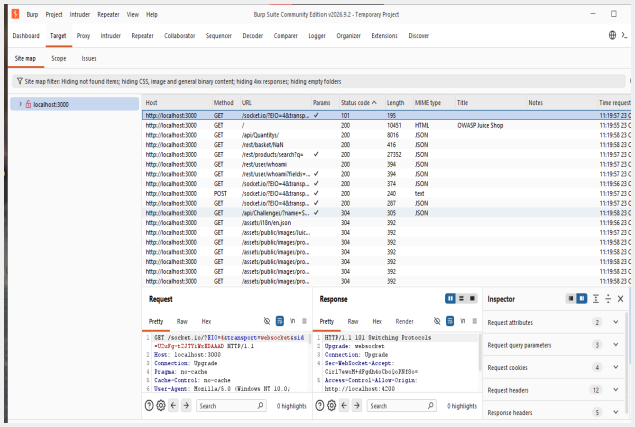
5. TABELA DE ROTAS, ENDPOINTS E VULNERABILIDADES

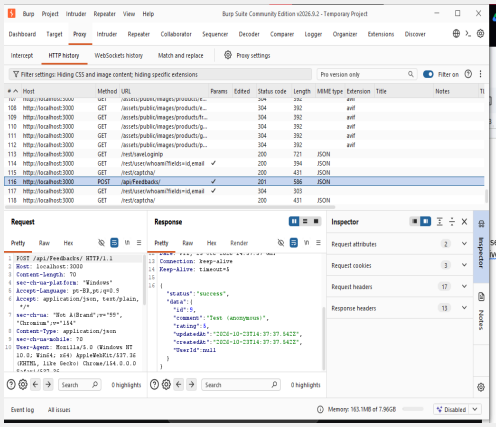
A tabela a seguir mostra todas as rotas mapeadas, arquivos identificados e vulnerabilidades detectadas durante a fase de reconhecimento:

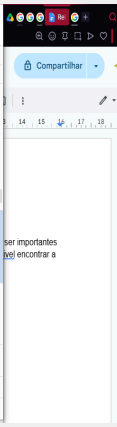
Rota / Endpoint / Recurso	Fonte de Descoberta	Descrição / Impacto de Segurança
/ftp/	Análise de Diretórios / Proxy	Permite o download de arquivos sensíveis do servidor, backups e arquivos .bak.
/#/administration	Código cliente (main.js)	Rota do painel administrativo identificada no main.js exposta ao público. Permite acesso administrativo caso possua usuário privilegiado (SQLi por exemplo)
/rest/basket/{id}	HTTP History (Burp)	Falha de IDOR na gestão de carrinho. Permite visualizar e alterar compras de terceiros trocando o ID numérico na URL.
/api/Memories	Interceptação de API (Burp)	Endpoint do mural de fotos expõe o objeto do usuário contendo ID, e-mail e hash da senha armazenada.
Barra de Pesquisa (/rest/products/search?q=)	Injeção de Parâmetros	Sanitização inadequada de entradas que permite execução de scripts maliciosos (DOM XSS).
/rest/admin/application-configuration	Interceptação de API (Burp)	Expõe configurações internas, e parâmetros do servidor.
/rest/products/reviews	Interceptação de API (Burp)	Endpoint de avaliações de produtos. Expõe publicamente os e-mails dos autores e permite enumeração de contas.
/api/Feedbacks	Interceptação e Repeater	Validação de CAPTCHA transmitida via JSON. Permite automação de spam, força bruta e forjamento de envios.
Interceptação de JSON / Feedback	Repeater (Burp)	Permite alterar parâmetros para enviar avaliações com 0 estrelas
Cabeçalho Authorization (JWT)	Decodificação no Burp	O token JWT traz metadados e informações do perfil do usuário em payload codificado em Base64 sem cifragem complementar.
Diretórios sem Permissão	Erros HTTP 500 (Express)	Respostas de erro não sanitizadas exibem o caminho físico interno de pastas do servidor.
Mural de Fotos / Postagens	Injeção de Caracteres	Inserção de caracteres inválidos (Zachi Cat) gera erros de exposição no client-side.

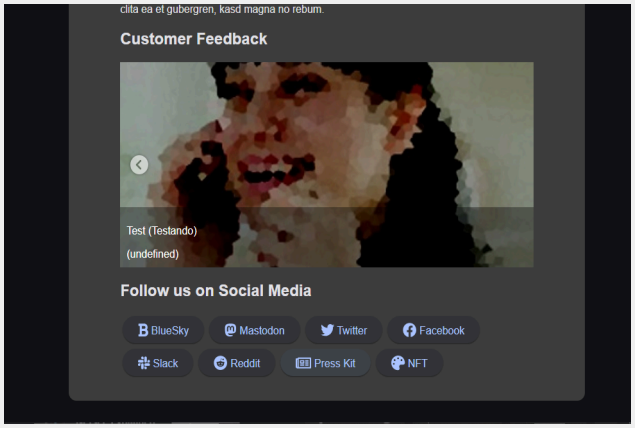

OWASP Juice Shop
You successfully solved a challenge: Admin Section (Access the administration section of the store.)
Jump to related coding challenge
Administration
Registered Users

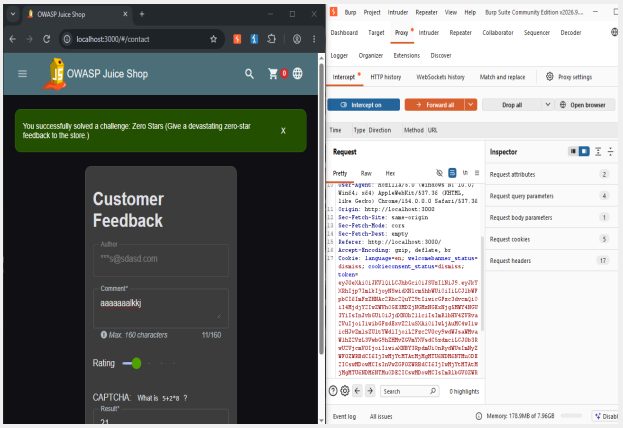

OWASP Juice Shop
All Products
EDGEBREACH_XSS_VISUAL_PROOF <script >alert('CANARY')</script>
edgebreach-xss
Apple Juice (1000ml)
1.99¤
Add to Basket
Basil Smoothie
2.99¤
Add to Basket

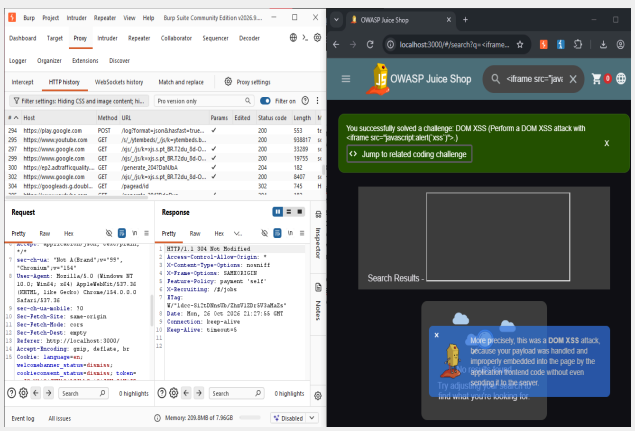

Burp Suite Community Edition v2026.9.2 - Temporary Project
Site map
Request
Response
Inspector

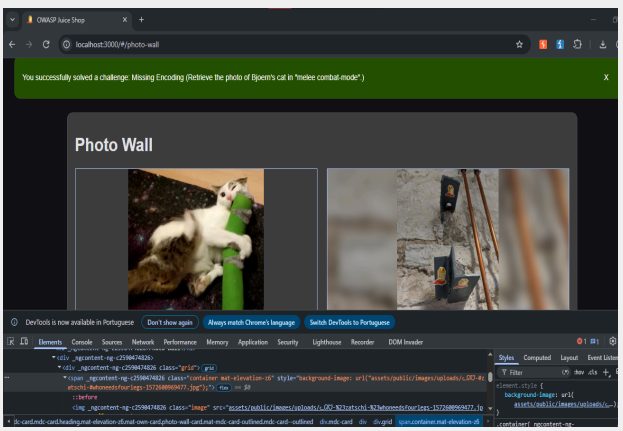

Burp Suite Community Edition v2026.9.2 - Temporary Project
HTTP history
Request
Response
Inspector


Compartilhar


Customer Feedback
Test (Testando)
(undefined)
Follow us on Social Media
BlueSky
Mastodon
Twitter
Facebook
Slack
Reddit
Press Kit
NFT


OWASP Juice Shop
You successfully solved a challenge: Zero Stars (Give a devastating zero-star feedback to the store.)
Customer Feedback
Comment*
aaaaaaaklkj
Rating
CAPTCHA: What is 5+2*8 ?


OWASP Juice Shop
You successfully solved a challenge: DOM XSS (Perform a DOM XSS attack with <iframe src="javascript:alert('xss')">.)
Jump to related coding challenge
Search Results -
More precisely, this was a DOM XSS attack, because your payload was handled and improperly embedded into the page by the application frontend code without even sending it to the server.


OWASP Juice Shop
You successfully solved a challenge: Missing Encoding (Retrieve the photo of Bjoern's cat in "melee combat-mode".)
Photo Wall